ChatGPT

Research Blueprint for a Complete HR Employee Management System

Your idea is best understood as an **employee lifecycle and workforce-management HR system**, not a payroll system. The product would become the central place where an employer manages employees from onboarding through attendance, leave, performance, documents, development and eventual offboarding, while payroll itself remains in an external accounting/payroll application. Modern HR platforms commonly combine employee records, employee self-service, onboarding, time and attendance, absence management, performance management, reporting and configurable workflows in this way. [1]

The most important architectural decision is to make the platform **configurable by each employer rather than hard-coding one company's HR rules**. For example, BambooHR supports custom time-off policies, SAP SuccessFactors supports role-specific onboarding/offboarding permissions, and enterprise HR products increasingly treat workflows, permissions, policies and review cycles as configurable components rather than fixed processes. [2]

For your payroll requirement specifically, I recommend calling the feature **Pay Records / Payroll Import**, not Payroll Processing. The system would **not calculate taxes, statutory deductions, gross pay, net pay or run payroll**. Instead, an authorized person uploads the finalized payroll results from an external payroll application using Excel or CSV; the HR system validates the file, matches each row to the correct employee, previews the changes, obtains approval if required, and then publishes that period's pay information to the employee's record. Microsoft uses a comparable import pattern of templates, required fields, mapping, duplicate handling, validation and import logs for structured business-data imports. [3]

The strongest version of your vision therefore looks like this:

Employee master record → organization structure → attendance and leave → onboarding → performance checkpoints → documents/training → external pay records → reporting → offboarding, all tied together through one workflow, approval, permissions, notification and audit system.

Product vision and boundaries

A good HR system should behave as the company's **system of record for employee-management information**. Employee self-service systems commonly let staff maintain personal information, clock in and out, request leave, review balances, access documents and complete HR processes without HR manually performing every transaction. Zoho People, for example, exposes profile information, attendance, leave, documents, goals and other HR information through employee self-service, while Oracle similarly exposes time and absence functions through self-service interfaces. [4]

Your application should be centered around one permanent **Employee Profile**, with everything else connected to it:

Area	Information the system should hold
Identity	Employee ID, legal/preferred name, contact information, emergency contact
Employment	Hire date, employment status, probation dates, employment type
Organization	Company, branch/location, department, team, position, manager, supervisor
Work	Schedule, shift, work location, attendance rules
Leave	Leave policies, balances, requests and history
Performance	Goals, checkpoints, appraisals, feedback and development plans
Documents	Contract, policies, certificates, HR letters and acknowledgements
Development	Skills, training, qualifications and certification expiry
Compensation	Current salary/rate if employer chooses to record it
Pay Records	Imported external payroll results, not calculations
Equipment	Laptop, phone, access card, keys, uniform or other company assets
Employee Relations	Restricted disciplinary, grievance or HR case records
Lifecycle	Onboarding, transfers/promotions and offboarding

Commercial systems already use this type of integrated model: BambooHR describes connections between employee records, time off, time tracking and performance, while Workday describes HCM as combining employee information with time, absence, workforce processes and analytics. [5]

The important difference in **your** platform should be flexibility. Instead of an employer adapting their processes to your software, they should be able to configure the software around their organization.

For example:

> **Company A:** Employee → Supervisor → Manager → HR approval
> **Company B:** Employee → Manager approval
> **Company C:** Employee → Department Head → HR
> **Company D:** Supervisor can approve sick leave, but vacation longer than five days requires Manager approval.

That same configurable approval engine should power leave, attendance corrections, onboarding steps, appraisals, employee changes, documents and potentially other HR requests. This avoids developing a different approval system inside every module.

One other important boundary is recruitment. An Applicant Tracking System could eventually be added, but it does **not need to be in the first version**. Your first lifecycle can begin once an applicant has been selected: HR creates or imports the new hire, which automatically launches onboarding. Recruiting can become a later module.

Role-based portals and permission model

The four perspectives you described are exactly the right starting point, but I would make permissions more granular underneath them. NIST defines role-based access control as assigning permissions to organizational roles rather than manually assigning permissions separately to every user; OWASP also stresses that authenticating someone does not mean that person should automatically be authorized to access every record or action in an application. [6]

In practice, your authorization model should be:

Role + relationship + scope + action.

For example, being a Supervisor should not mean seeing *every employee*. It should mean being able to perform permitted Supervisor actions on employees who report to that Supervisor. A Manager might see the Supervisor's teams underneath them. An HR Administrator might see the entire company. This is more appropriate than a simple Employee/Admin switch. [7]

Recommended portal design

Capability	Employee	Supervisor	Manager	Admin
View own profile	✓	✓	✓	✓
Edit permitted own details	✓	✓	✓	✓
Clock in/out	✓	✓	✓	✓
View own attendance	✓	✓	✓	✓
Correct own missed punch	Request	Request	Request	Direct/configurable
View direct-report attendance	—	✓	✓	✓
Submit leave	✓	✓	✓	✓
Approve direct-report leave	—	✓	✓	Configurable
View team leave calendar	Limited	✓	✓	✓
Complete self-appraisal	✓	✓	✓	✓
Appraise direct reports	—	✓	✓	Configurable
Department appraisal oversight	—	Limited	✓	✓
Complete onboarding tasks	✓	✓	✓	✓
Build onboarding templates	—	—	Optional	✓
View own imported pay records	✓	✓ own	✓ own	Permission-based

Capability	Employee	Supervisor	Manager	Admin
View employee pay	—	**No by default**	**No by default**	Restricted permission
Upload payroll file	—	—	—	Restricted permission
Create employee	—	—	Optional	✓
Change roles/permissions	—	—	—	Restricted Admin
View audit logs	—	Limited	Limited	✓

That last distinction matters. **Supervisor and Manager should not automatically mean salary/payroll visibility.** Some companies authorize managers to see compensation; others do not. Make compensation access a separate permission.

I would similarly split your Admin capability internally into at least two permission bundles:

HR Admin manages employee records, HR workflows, leave, appraisals, onboarding and HR documents.

System Admin manages users, authentication, integrations and technical configuration.

This separation means an IT administrator can reset someone's login without automatically receiving permission to view confidential medical documents, salaries, appraisals or disciplinary cases. That approach follows the broader security principle of limiting authorization to what a role actually requires. [8]

I would also introduce an optional **Payroll Importer** permission. That person can upload finalized payroll results but does not necessarily need the ability to edit performance reviews or confidential employee-relations cases.

Core modules your complete system should contain

Research across BambooHR, Workday, Zoho People, Rippling, Oracle and Odoo shows substantial convergence around employee records, self-service, attendance/time, absence, onboarding, performance, reporting and lifecycle automation. [9]

Your finished product should therefore contain the following modules.

Module	Recommended capabilities	Priority
Employee Management	Employee profiles, employment details, departments, titles, locations, supervisors/managers, status history	Essential
Organization Structure	Departments, teams, locations, positions, reporting lines, organization chart	Essential

Module	Recommended capabilities	Priority
Authentication & Access	Login, password recovery, MFA, roles, permissions, scoped access	Essential
Attendance	Sign in/out, breaks, schedules, missed punches, late/early tracking, corrections, overtime records	Essential
Leave & Absence	Vacation, sick, unpaid and unlimited employer-defined leave types	Essential
Onboarding	Employer-created onboarding workflows, forms, tasks, documents, training, equipment	Essential
Performance	Employer-created appraisal checkpoints, goals, self-review, supervisor review, feedback and sign-off	Essential
Documents	Employee documents, policies, contracts, acknowledgements, expirations, versions	Essential
Pay Records Import	Excel/CSV import of externally calculated payroll results	Essential
Workflow/Approvals	Configurable approval routes powering all modules	Essential
Notifications	In-app/email reminders, overdue tasks, decisions, upcoming deadlines	Essential
Reporting & Dashboards	Headcount, attendance, absence, appraisal, onboarding and employee reports	Essential
Offboarding	Exit checklist, assets, document collection, account shutdown workflow	High
Employee Requests	HR letters, information changes, attendance correction and other configurable requests	High
Training/ Certifications	Courses, qualifications, required training, expiry reminders	High
Asset Management	Laptops, keys, phones, uniforms, cards and return status	High
Employee Relations Cases	Grievances, discipline, investigations, incidents and confidential HR notes	High
Announcements	Company/department announcements and acknowledgements	Medium
Surveys/ Engagement	Employee surveys and pulse questionnaires	Medium
Recognition	Employee recognition/awards	Medium
Recruitment/ATS	Vacancy → candidate → offer → onboarding	Later

Module	Recommended capabilities	Priority
API/Integrations	SSO, calendars, accounting/payroll exports, third-party systems	High for mature product

Attendance and clocking

Your sign-in/sign-out requirement should become a full **Time & Attendance** module rather than just two buttons. Modern systems support web/mobile clocking, missed-punch correction, attendance rules and sometimes IP/location restrictions. Zoho People, for example, supports real-time attendance, configurable settings, regularization of missed entries, IP/location restrictions and manager approval of corrections; Workday similarly supports time capture and attendance management. [10]

A daily record could look like:

Scheduled: 8:30 AM–5:00 PM
Clock in: 8:37 AM
Lunch out: 12:31 PM
Lunch in: 1:28 PM
Clock out: 5:06 PM
Worked: calculated duration
Late: 7 minutes
Status: Completed

The employer should configure:

- working schedules and shifts;
- grace periods;
- required breaks;
- whether overtime needs approval;
- rounding rules;
- attendance locations;
- whether mobile clocking is permitted;
- what happens when an employee forgets to clock out.

Most importantly, **never silently overwrite a clock punch**. If Employee A clocked in at 8:45 and a Supervisor later corrects it to 8:30, preserve both:

> Original: 8:45 AM
> Correction requested: 8:30 AM
> Reason: Employee forgot to clock in
> Approved by: Supervisor
> Approval date/time: …

That creates an auditable attendance history rather than allowing historical records to quietly change.

Leave and “all sorts of days”

You should not build separate programming logic for Sick Day, Vacation Day, Personal Day and every future type. Build a **Leave Type Builder**.

BambooHR's current product supports custom time-off policies and different rules by organization/location/ employee grouping, while Oracle's self-service absence design allows employees to enter requests and review entitlement balances. [11]

An employer should be able to create:

Vacation
Sick
Personal
Bereavement
Maternity
Paternity/Parental
Compassionate
Unpaid
Study
Medical Appointment
Time Off in Lieu
Jury/Civic Duty
Administrative Leave
Work From Home Request
Custom Company Leave

For every type, configure:

Paid/unpaid → entitlement → accrual → carryover → maximum balance → minimum notice → maximum consecutive days → attachment requirement → approval chain → eligible employees → blackout dates → half-day/hourly permitted → negative balances permitted.

Employees should see the request status and their available balance before submitting. Managers need a team calendar so they can identify overlapping leave. This pattern is common in modern leave-management products. [12]

Documents and employee files

Create a central document repository with permissions and categories:

Contracts, identification, qualifications, certificates, policy acknowledgements, HR letters, medical documentation, imported pay statements and appraisal documents should all be capable of being attached to an employee while having different visibility rules.

Include expiration dates and alerts. For example:

Food Handler Certificate expires in 30 days → employee + supervisor + HR notified.

Policy documents should support acknowledgement:

Employee Handbook v3.2
Published: September 1
Employee opened: September 2
Acknowledged: September 2 at 10:41 AM

That is considerably stronger than simply storing a PDF.

How the major workflows should operate

The single most important feature that will make the whole platform feel unified is a **workflow engine**.

Rather than your programmers creating completely different logic for onboarding, vacation approval and appraisals, those modules should call a common workflow system:

Trigger → Rules → Tasks → Approvers → Deadlines → Reminders → Escalation → Completion → Audit entry.

This is consistent with how enterprise HR products separate HR processes into configurable tasks, permissions and process stages. SAP SuccessFactors, for example, supports permissions by onboarding/offboarding task type and electronic document-signing flows, while modern HR suites increasingly connect onboarding with employee records and other workforce modules. [13]

Your onboarding vision

This should be one of the strongest parts of the system.

The employer creates an **Onboarding Template**.

Example:

Template: New Customer Service Representative – Kingston

Employee completes personal information
↓
Employee uploads required identification
↓
Employee reviews employment policies
↓
Employee signs acknowledgement
↓
Supervisor assigns initial schedule
↓

Admin assigns employee number
↓
IT prepares email/account
↓
Equipment assigned
↓
Required training completed
↓
Supervisor completes Week One checkpoint
↓
Thirty-day probation checkpoint
↓
Sixty-day checkpoint
↓
Ninety-day probation appraisal
↓
Onboarding complete

Templates should vary by position, department, location or employment type.

Each task should contain:

Owner, instructions, due date, dependencies, form/document, required/optional status, approval requirement, completion evidence and reminders.

A dashboard could show:

John Brown — 92% Complete
Sarah Blake — 67% Complete — 2 overdue tasks
Mark Lewis — 100% Complete

Electronic signatures are particularly useful in onboarding and offboarding; SAP's onboarding documentation specifically supports e-signatures as part of those processes. [14]

Your appraisal/checkpoint vision

Your instinct to think of appraisals as **employer-created checkpoints** is very good.

Do not build a system that says, “Everyone gets an annual appraisal on December 31.”

Build a **Performance Cycle / Checkpoint Builder**.

CIPD's January 2026 guidance notes that structured performance reviews remain important but should sit within a broader performance-management cycle, while its performance-management guidance recommends regular, timely feedback rather than treating performance as one isolated annual event. [15]

An employer could configure:

New employee: 30 / 60 / 90-day checkpoints
Permanent employee: quarterly checkpoints
Management: twice-yearly review
Probation employee: final probation appraisal
Poor-performance case: monthly improvement checkpoints

Each checkpoint template could include:

Goals

Customer satisfaction goal — 90%
Attendance goal — 95%
Sales target — $X

Competencies

Communication
Teamwork
Reliability
Leadership
Customer service
Technical competency

Questions

What went well during this period?
What could be improved?
What support does the employee need?

Ratings

Exceptional
Exceeds expectations
Meets expectations
Needs improvement
Unsatisfactory

Or configurable numeric scales.

A sophisticated appraisal flow should support:

Employee self-evaluation
↓
Supervisor review

↓
Meeting/check-in
↓
Manager review/calibration if required
↓
Employee acknowledgement
↓
Development objectives created
↓
Next checkpoint scheduled

Optional capabilities should include peer/360° feedback, goals, competency libraries, one-to-one meeting notes, achievements and development plans. SAP SuccessFactors, for example, combines goal setting, continuous feedback, performance reviews and 360-degree reviews, and allows ongoing achievements/feedback to feed into performance processes. [16]

One feature I strongly recommend is **“Previous Checkpoint → Current Checkpoint” comparison**. A supervisor should be able to see whether an employee's rating or goal changed over time instead of viewing each review in isolation.

Performance records should not be freely editable once finalized. Changes should either require reopening the appraisal with authorization or create a version history.

Attendance and leave working together

These modules need to communicate.

Suppose:

Employee has approved vacation September 10–12.

The Attendance system should know the employee is not expected to clock in during those days.

If the employee is absent without an approved leave request, the system could mark:

Scheduled: Yes
Clock-in: None
Approved leave: None
Attendance status: Unresolved absence

The employer could then determine whether the employee submits sick leave, an attendance correction or another explanation.

Likewise, approved leave should update the team calendar and balance immediately.

Offboarding

Onboarding without offboarding leaves the employee lifecycle unfinished.

When HR changes an employee to “Terminating,” trigger an employer-defined checklist:

> Final work date recorded
> ↓
> outstanding leave reviewed
> ↓
> company assets returned
> ↓
> employee documents completed
> ↓
> exit interview completed
> ↓
> accounts/access disabled
> ↓
> reporting relationship reassigned
> ↓
> employee changed to inactive/archive

SAP's current onboarding platform similarly treats onboarding and offboarding as structured processes consisting of tasks and document flows. [17]

Do **not** delete former employees merely because they leave. Their account should become inactive while records are retained or disposed of according to the organization's applicable retention requirements.

External payroll import and employee pay records

This is where I would modify the original vision slightly.

You said that payroll will be completed **outside** your HR system and someone will upload an Excel sheet that automatically adjusts everyone's payroll information.

That is absolutely feasible, but the system should distinguish **two fundamentally different imports**.

Pay Run Results Import

This is the normal recurring upload.

Example:

> Payroll was calculated externally for August 1–15.
> Authorized user exports the payroll results.

HR system imports them.
Employees can then see their finalized August 1–15 pay information.

Suggested template:

Field	Required?
Employee ID	Yes
Pay Period Start	Yes
Pay Period End	Yes
Payment Date	Yes
Currency	Yes
Gross Pay	Recommended
Regular Pay	Optional
Overtime Pay	Optional
Allowances	Optional
Bonus	Optional
Tax	Optional
Other Deductions	Optional
Net Pay	Yes
External Payroll Reference	Recommended

The system merely **records what the payroll application calculated**.

It does not determine:

Gross → deductions → taxes → statutory contribution → net.

That keeps payroll processing out of your product.

Compensation Change Import

This is different.

Suppose the external spreadsheet contains:

Employee ID	Effective Date	Old Salary	New Salary
EMP001	2026-09-01	100,000	110,000
EMP002	2026-09-01	125,000	135,000

This import actually updates an employee's compensation record.

You should **not combine this with regular payroll-result uploads** because one shows what someone was paid for a period while the other changes their underlying compensation.

That distinction will prevent a very dangerous class of mistakes.

The upload process should not instantly change records

Even though the goal is automation, I strongly recommend against:

> Upload Excel → immediately overwrite 500 employee records.

Instead:

Upload → Validate → Map → Preview → Approve → Post → Audit.

Microsoft's current business-data import workflow similarly checks required columns, maps incoming columns to application fields, supports duplicate handling and produces import status/log information. [3]

Example:

> **Payroll Import — August 15**
>
> Rows found: 247
> Employees matched: 244
> Unmatched: 2
> Duplicate: 1
> Invalid amount: 0
>
> Total external net pay: J$18,423,450
> Total rows to post: J$18,423,450
>
> **Status: Cannot post until 3 exceptions are resolved**

The two unmatched employees should appear clearly:

> Employee ID 98371 — no employee found
> Employee ID 77112 — no employee found

Never quietly create a new employee because their name appears in a payroll spreadsheet.

Match employees by immutable Employee ID

Do **not** use someone's name as the primary payroll matching key.

You could easily have:

> Andre Brown
> Andre Brown

or:

> Shanice McDonald
> Shanice Mc Donald

Every employee needs a unique, immutable internal ID such as:

`EMP-00001258`

The payroll import should primarily use that identifier.

Microsoft's import systems similarly use field mapping and alternate keys to uniquely identify/update data during imports. [3]

Import history and rollback

Every upload should produce an immutable batch:

> Import ID: PAY-2026-08-15-003
> Uploaded by: Jane Smith
> Uploaded: Aug 15, 2026 4:42 PM
> Approved by: David Brown
> Rows: 247
> Status: Posted
> Source file hash: ...

You should retain:

- original uploaded file;
- parsed values;
- rejected rows;
- employee matches;
- who uploaded it;
- who approved it;
- timestamp;

• changes caused by the import.

OWASP recommends application-level logging for both operational and security events because application logs provide visibility not available from infrastructure logs alone. [18]

Employee Pay Records page

The Employee portal could show:

> **My Pay Records**
>
> Aug 15, 2026 — View
> Jul 31, 2026 — View
> Jul 15, 2026 — View

Opening one:

> Pay Period: August 1–15
> Gross: J$125,000
> Deductions: J$26,415
> Net: J$98,585
> Payment Date: August 15
>
> Source: Imported finalized payroll

You could also allow the employer to upload PDF payslips and link each one to the corresponding employee/pay period.

Again, your application is **displaying and storing payroll results**, not running payroll.

Excel security matters

Because your system accepts files, uploads are themselves a security boundary. OWASP recommends allowing only business-required extensions, validating file types rather than trusting browser-supplied content types, limiting file size, generating safe server-side filenames and permitting uploads only from authorized users. [19]

CSV exports deserve special protection as well: OWASP documents “CSV Injection,” where spreadsheet applications interpret cells beginning with certain characters as formulas. Any data your HR system exports back to spreadsheet formats needs formula-injection protections. [20]

Data architecture, automation and reporting

The success of the product will depend less on the number of screens than on whether the underlying information is connected correctly.

The **Employee** should be the central object.

Conceptually:

```
Company
  ├── Locations
  ├── Departments
  │     └── Positions
  │           └── Employees
  │
  ├── Leave Policies
  ├── Attendance Policies
  ├── Onboarding Templates
  ├── Performance Templates
  └── Workflow Rules

Employee
  ├── Employment History
  ├── Reporting Relationships
  ├── Attendance
  ├── Leave Requests
  ├── Leave Balances
  ├── Performance Checkpoints
  ├── Goals
  ├── Documents
  ├── Training
  ├── Assets
  ├── Imported Pay Records
  ├── HR Requests
  └── Offboarding
```

Use effective-dated records

Do not simply store:

> John's salary = 120,000.

Store:

> 100,000 — Jan 1, 2025 to Dec 31, 2025
> 110,000 — Jan 1, 2026 to Jun 30, 2026
> 120,000 — effective Jul 1, 2026

Do the same for:

Manager, department, title, location, employment status, salary/rate, schedule and leave-policy assignment.

Otherwise historical reporting eventually becomes incorrect. For example, without effective dating, moving John from Sales to Operations could make last year's Sales report incorrectly behave as though John had always worked in Operations.

Build a reusable approval engine

A request should use standardized statuses such as:

```
Draft
   ↓
Submitted
   ↓
Pending Supervisor
   ↓
Pending Manager
   ↓
Approved
```

Or:

```
Submitted
   ↓
Needs Changes
   ↓
Resubmitted
   ↓
Approved
```

Alternative outcomes:

```
Rejected
Cancelled
Expired
Withdrawn
```

The Admin should be able to define rules such as:

> Vacation ≤ 2 days → Supervisor
> Vacation > 2 days → Supervisor + Manager

Unpaid leave → Supervisor + Manager + HR
Sick leave > 2 days → supporting document required

The same engine should handle:

Attendance corrections
leave
compensation changes
employee profile changes
onboarding approvals
appraisal approvals
HR requests

Automation engine

Once modules share employee information, powerful automation becomes possible.

Examples:

Employee created
→ Create portal account
→ Assign onboarding template
→ Notify Supervisor
→ Generate employee number

Employee misses expected clock-in
→ Notify employee after configured threshold

Leave approved
→ Deduct/update balance
→ Update team calendar
→ Attendance system marks approved absence
→ Notify employee

Appraisal due in seven days
→ Notify employee + Supervisor

Appraisal overdue
→ Reminder
→ Escalate to Manager after employer-defined number of days

Certification expires in thirty days
→ Employee + Supervisor notified

Probation ends in fourteen days
→ Trigger probation checkpoint

Employee termination entered
→ Launch offboarding checklist
→ Notify relevant departments
→ Schedule portal-access termination

This automation layer is what will make your product feel like **one HR system instead of a collection of unrelated forms**.

Dashboard design

The Employee dashboard should prioritize actions:

- Clock In / Clock Out
- Leave balance
- Upcoming leave
- Appraisal due
- Onboarding tasks
- Outstanding documents
- Latest pay record
- Company announcements

Supervisor:

- Who is working today
- Late/missing punches
- Direct reports away
- Requests awaiting approval
- Upcoming appraisals
- Probation deadlines
- Team onboarding status

Manager:

- Department attendance
- Leave coverage/calendar
- Approval escalation
- Performance completion
- Employees on probation
- Onboarding status
- Turnover/headcount trends
- Supervisor workload

Admin:

- Headcount
- New hires

Departures
Leave requests
Attendance exceptions
Onboarding completion
Appraisal completion
Expiring documents/certifications
Payroll-import status/errors
HR requests
Audit/security alerts

Reporting is a standard capability of comprehensive HR products; Zoho explicitly identifies reporting and analytics alongside employee records, onboarding, leave, attendance and performance, while Oracle provides self-service workforce reporting to managers and HR users. [21]

Reports worth including

Useful initial reports include:

Report family	Examples
Workforce	Headcount by department/location/status
Attendance	Late arrivals, absent days, worked hours, missed punches
Leave	Balances, leave usage, upcoming leave, absenteeism
Performance	Appraisal completion, ratings distribution, overdue checkpoints
Onboarding	Completion %, overdue tasks, average completion time
Employee lifecycle	New hires, probation ending, transfers, exits
Documents	Missing/expired documents and certifications
Payroll imports	Import batches, unmatched employees, posting history
Audit	Record changes, approvals, imports, permission changes

Reports should honor the same permission rules as the normal application. A Supervisor should not be able to create a custom report that indirectly exposes data they cannot see on an employee's profile.

Security, privacy, accessibility and compliance

An HR platform stores unusually sensitive information: addresses, contact details, performance history, attendance, salaries/pay records, medical documentation and potentially identification documents. Security therefore cannot be added at the end.

OWASP treats authorization flaws as a major web-application risk and recommends robust authorization checks appropriate to the application's business context. [22]

At minimum, build:

MFA, especially for administrators and people who access pay or confidential HR records. OWASP recommends MFA broadly and particularly for privileged users; NIST's current SP 800-63B guidance also recognizes phishing-resistant authenticators such as properly configured WebAuthn authenticators. [23]

Secure authentication, including rate limiting/login throttling, safe password storage, secure account recovery and reauthentication before sensitive operations. OWASP provides explicit guidance in each of these areas. [24]

Encryption in transit and at rest.

Complete audit trails for access-sensitive changes, approvals, imports, permission changes and authentication events. OWASP recommends consistent application logging for both security monitoring and operational troubleshooting. [18]

Session controls, automatic expiration, device/session management and immediate revocation when employment ends.

Tenant isolation if multiple employers use the product. One company's employees must never be accessible to another company.

Backups and disaster recovery.

Document malware/file protections for uploads. [19]

Least-privilege access for managers, supervisors and administrators. [8]

Jamaica-specific consideration

Because this product may be deployed in Jamaica, the Jamaican Data Protection Act should influence the architecture from the beginning rather than being treated as a later legal checkbox.

The Office of the Information Commissioner identifies data-protection principles including purpose limitation, data minimization, accuracy and storage limitation, and lists rights including access, rectification, erasure, restriction, portability, objection and protection regarding solely automated individual decision-making. It also calls for appropriate technical and organizational safeguards such as encryption and measures supporting confidentiality, integrity, availability and recovery. [25]

That means your product should eventually support:

> “Show me the personal information you hold about me.”
>
> “This address is incorrect; request correction.”
>
> “What is this information being used for?”

“Export my information where legally applicable.”

retention/disposal policies by document or data category.

It also means you should be particularly careful with **GPS, facial recognition and biometrics for attendance**. Although modern attendance platforms offer location restrictions and biometric integrations, Jamaica's OIC explicitly identifies biometric information as personal data and emphasizes data minimization. Therefore, ordinary web/mobile clocking should work without forcing employers into unnecessary biometric collection; advanced location/biometric attendance should be optional and policy-controlled. [26]

For performance-management AI, I would likewise avoid letting an AI system autonomously decide promotions, discipline or termination. AI could summarize manager comments or suggest wording, but significant employment decisions should remain human-controlled, especially given Jamaica's protections concerning solely automated decision-making that significantly affects individuals. [25]

Leave laws should not be hard-coded

For example, Jamaica's Ministry of Labour and Social Security currently states that under the Holidays with Pay Order workers are entitled to ten days of sick leave per year. Jamaica separately regulates matters including holidays with pay and maternity leave. [27]

However, your software should **not contain “10 sick days” permanently in application code**.

Instead:

Country policy template: Jamaica
Employer policy: 10 sick days
Effective from: [date]
Eligibility rules: [configuration]

This allows the employer to comply with legislation, contracts, collective agreements or more generous company policies, and allows future legal changes without rewriting your application.

The same philosophy should apply internationally.

Accessibility

Target **WCAG 2.2 AA** for the web product. W3C recommends WCAG 2.2 for current accessibility efforts and the standard covers web experiences across desktop, mobile and other devices. [28]

That means forms, clock-in buttons, appraisal screens and approval workflows need proper keyboard access, visible focus, labels, accessible errors, sufficient target sizes and compatible authentication experiences rather than accessibility being limited to static pages. WCAG 2.2 specifically added criteria addressing focus visibility, target sizes, redundant entry and accessible authentication. [28]

Recommended MVP and expansion roadmap

Do **not** try to build every module simultaneously. The product becomes valuable when a smaller number of modules are deeply connected rather than when it has thirty unfinished menus.

First release

The first production-ready version should contain:

Capability	What must work
Company configuration	Company, departments, locations, positions
Employee records	Create/edit/inactivate employees
Reporting structure	Manager/supervisor relationships
Authentication	Secure login, recovery, MFA for privileged accounts
Permissions	Employee/Supervisor/Manager/Admin scopes
Employee portal	Profile, attendance, leave, tasks, appraisals, pay records
Supervisor portal	Direct reports, attendance, approvals, checkpoints
Manager portal	Department/team overview, approvals, performance
Admin portal	Full HR configuration and administration
Attendance	Clock in/out, schedules, exceptions, corrections
Leave	Custom leave types, balances, requests and approvals
Onboarding	Templates, tasks, due dates and progress
Performance	Configurable checkpoints and review cycles
Documents	Employee files and policy acknowledgements
Pay Records	XLSX/CSV finalized payroll import
Workflow engine	Configurable approvals
Notifications	Email + in-app
Reporting	Core workforce/attendance/leave/performance reports
Audit	Changes, approvals, imports and access-sensitive events

That already gives you a legitimate full employee-management product rather than a simple attendance application. Those areas correspond closely with the functions repeatedly found across established HR suites. [29]

Second release

Once the core is stable, add:

- Shift scheduling and advanced attendance rules
- 360-degree appraisal feedback
- Goals and one-to-one check-ins
- Probation automation
- Offboarding
- Training and certification tracking
- Asset management
- Employee HR-request center
- Grievance/disciplinary case management
- Advanced dashboards
- Custom report builder
- Calendar integrations
- Public API/webhooks
- SSO
- Mobile/PWA improvements

Continuous feedback and goals are natural additions after the basic appraisal engine because modern performance systems increasingly combine formal reviews with ongoing goals and feedback. [30]

Later product expansion

After customers are using the system and you understand their needs, add:

- Applicant tracking/recruitment
- Offer-letter generation
- Candidate-to-employee conversion
- Learning-management integrations
- Employee engagement surveys
- Succession/talent planning
- Workforce planning
- Advanced analytics
- Third-party payroll/accounting connectors
- White-label branding
- Multiple languages
- Multi-country policy packs

The architecture I would build around

Conceptually, there should be **one HR platform with shared services underneath every module**:

```
                     EMPLOYER CONFIGURATION
                               │
```

```
            ┌──────────────────────┼─────────────────────┐
            │                      │                     │
     Organization                HR Policies          Workflow Rules
            │                      │                     │
            └──────────────────────┼─────────────────────┘
                                   │
                         EMPLOYEE MASTER RECORD
                                   │
      ┌─────────────┬──────────────┼─────────────┬─────────────┐
      │             │              │             │             │
 Attendance      Leave        Onboarding    Performance    Documents
      │             │              │             │             │
      └─────────────┴──────────────┼─────────────┴─────────────┘
                                   │
                    PAY RECORD IMPORT / EXTERNAL PAYROLL
                                   │
                                   ▼
                         REPORTING & ANALYTICS
                                   │
                                   ▼
                       OFFBOARDING / ARCHIVE
```

Supporting all of those modules:

```
Authentication
Role & Permission Engine
Workflow / Approval Engine
Notification Engine
Document Storage
Audit Log
Reporting Engine
Import / Export Engine
API / Integration Layer
Privacy & Retention Controls
```

That is the part of your vision I would emphasize most strongly. **Do not build “a leave page,” “an appraisal page,” “a clock-in page” and “an onboarding page” as isolated features. Build an employee platform where every module understands the same employee, reporting structure, policies, permissions and workflows.**

For example, one employee promotion could automatically:

```
Manager changes employee position
        ↓
```

```
Approval workflow runs
        ↓
Employment history updated
        ↓
Department/reporting structure changes
        ↓
New Supervisor gains permitted access
        ↓
Old Supervisor loses access
        ↓
New appraisal template assigned
        ↓
New attendance/leave policy applied if appropriate
        ↓
Required training triggered
        ↓
Change recorded in audit history
```

Likewise, an employee's approved vacation should automatically influence their attendance expectations; an onboarding probation milestone should create an appraisal checkpoint; offboarding should remove future appraisal tasks and ultimately deactivate login access; and an imported finalized pay record should appear only to the employee and specifically authorized staff.

That interconnected behavior is what transforms the concept from **“HR software with a lot of features” into a genuine HR information system**.

The clearest product definition for what you are describing is therefore:

> **A configurable employee lifecycle and workforce-management HRIS with role-based Employee, Supervisor, Manager and Administrator portals; employee records; attendance and time capture; employer-defined leave policies; workflow-driven onboarding; configurable performance checkpoints and appraisals; documents; employee self-service; reporting; offboarding; and secure import/display of payroll results generated by external payroll systems—without performing payroll calculations itself.**

That scope preserves your original idea while filling the major gaps found in a mature HR-management platform. It also gives you a clean product boundary: **your system manages the employee and their HR lifecycle; the external payroll system calculates the pay; your system securely receives and displays the finalized results.**

---

[1] What is an HR system and why is it important?
https://www.bamboohr.com/uk/blog/hr-system?utm_source=chatgpt.com

[2] [5] [11] [12] Track and Automate PTO with Time Off Management Software | BambooHR
https://www.bamboohr.com/ca/platform/time-and-attendance/time-off

3 Import data in model-driven apps - Power Apps | Microsoft Learn
https://learn.microsoft.com/en-us/power-apps/user/import-data

4 What activities can employees complete using the ...
https://www.zoho.com/people/hrknowledgehive/What-activities-can-employees-complete-using-the-employee-self-service-portal.html?utm_source=chatgpt.com

6 role-based access control (RBAC) - Glossary | CSRC
https://csrc.nist.gov/glossary/term/role_based_access_control?utm_source=chatgpt.com

7 Adding Attributes to Role Based Access Control
https://www.nist.gov/publications/adding-attributes-role-based-access-control?utm_source=chatgpt.com

8 22 Authorization - OWASP Cheat Sheet Series
https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html

9 29 Get BambooHR ® Plans and Pricing
https://www.bamboohr.com/pricing/?utm_source=chatgpt.com

10 26 Attendance Management System | HRMS Attendance | Zoho People
https://www.zoho.com/people/attendance-management-system.html

13 Role-Based Permissions for Onboarding and Offboarding ...
https://help.sap.com/docs/successfactors-onboarding/implementing-onboarding/role-based-permissions-for-onboarding-and-offboarding-tasks?utm_source=chatgpt.com

14 e-Signature Methods Supported in Onboarding and ...
https://help.sap.com/docs/successfactors-onboarding/implementing-onboarding/e-signature-methods-supported-in-onboarding-and-offboarding?utm_source=chatgpt.com

15 Performance Reviews | Factsheets | CIPD
https://www.cipd.org/en/knowledge/factsheets/appraisals-factsheet/

16 Performance & Goals Management with Integration to ...
https://help.sap.com/docs/successfactors-performance-and-goals/sap-best-practices-for-sap-successfactors-performance-and-goals/performance-goals-management-with-integration-to-development-planning-8a685906c0554a67980ca6e8a026a38e?utm_source=chatgpt.com

17 Onboarding and Offboarding Standard Processes
https://help.sap.com/docs/successfactors-onboarding/implementing-onboarding/onboarding-and-offboarding-standard-processes?utm_source=chatgpt.com

18 Logging - OWASP Cheat Sheet Series
https://cheatsheetseries.owasp.org/cheatsheets/Logging_Cheat_Sheet.html

19 File Upload - OWASP Cheat Sheet Series
https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html

20 CSV Injection
https://owasp.org/www-community/attacks/CSV_Injection?utm_source=chatgpt.com

21 What is Employee Management Software? | HR Glossary
https://www.zoho.com/people/hr-glossary/employee-management-software.html?utm_source=chatgpt.com

23 Multifactor Authentication - OWASP Cheat Sheet Series
https://cheatsheetseries.owasp.org/cheatsheets/Multifactor_Authentication_Cheat_Sheet.html?utm_source=chatgpt.com

[24] Authentication - OWASP Cheat Sheet Series
https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html

[25] The Office of the Information Commissioner – Office of the Prime Minister
https://opm.gov.jm/the-office-of-the-information-commissioner/

[27] FAQ – Ministry of Labour and Social Security
https://www.mlss.gov.jm/faq/?utm_source=chatgpt.com

[28] Web Content Accessibility Guidelines (WCAG) 2.2
https://www.w3.org/TR/WCAG22/

[30] Performance Management | Factsheets
https://www.cipd.org/en/knowledge/factsheets/performance-factsheet/?utm_source=chatgpt.com